



# LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



## Fastjson 1.x RCE Targeting Daily Defender Review

### Threat Report

|                       |                 |
|-----------------------|-----------------|
| <b>Classification</b> | TLP:CLEAR       |
| <b>Published</b>      | 2026-08-02      |
| <b>Version</b>        | 1.0             |
| <b>Author</b>         | Lost Boys Cyber |
| <b>Report Type</b>    | Threat Report   |

TLP:CLEAR | Lost Boys Cyber | Fastjson 1.x RCE Targeting Daily Defender Review - Threat Report

Published: 2026-08-02 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

## Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Activity Overview
5. Affected Sectors and Exposure
6. Tactics, Techniques, and Procedures
7. Infrastructure and Indicators
8. Detection Engineering
  - 8.1. Detection Summary
  - 8.2. Sigma / Detection Content
  - 8.3. Hunt Query
9. Threat Hunting
  - 9.1. Hunt Hypothesis
  - 9.2. Hunt Query
10. Risk Assessment
11. Recommended Actions
12. References

# Fastjson 1.x RCE Targeting Daily Defender Review

## 1. Executive Summary

Fastjson remains a recurring Java attack surface where unsafe deserialization/parser behavior can become remote-code-execution risk in exposed applications. Daily prioritization is warranted when public reporting describes active targeting or patch uncertainty, especially in internet-facing Java services and third-party products bundling outdated Fastjson 1.x components.

Daily defender priority: convert the article/advisory signal into inventory, telemetry, and response checks instead of waiting for perfect attribution. This report is written for operational review and should be validated against local exposure.

## 2. Intelligence Requirements

| Question                 | Current Answer                                                                                                                               | Confidence |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|------------|
| What is the daily topic? | Fastjson 1.x remote-code-execution exposure with attack reports                                                                              | Medium     |
| Who is most exposed?     | Internet-facing Java services, API gateways, middleware stacks, and internally developed applications with transitive Fastjson dependencies. | Medium     |
| Are hard IOCs available? | No reliable atomic IOCs were present in the selected daily sources; hunt logic is behavior-based.                                            | High       |

## 3. Source Review & Confidence

| Source                         | Contribution                                                                         | Confidence |
|--------------------------------|--------------------------------------------------------------------------------------|------------|
| The Hacker News security index | Current index snippet referencing Fastjson 1.x RCE attacks and no patch availability | Medium     |
| Alibaba Fastjson project       | Project/source repository for version and maintenance context                        | Medium     |
| NVD CVE search                 | CVE/catalog context for Fastjson vulnerability exposure                              | Medium     |

Where the selected sources are sector guidance or article indexes rather than primary incident advisories, confidence is higher for operational relevance than for attacker attribution or victim-specific details.

## 4. Threat Activity Overview

Fastjson remains a recurring Java attack surface where unsafe deserialization/parser behavior can become remote-code-execution risk in exposed applications. Daily prioritization is warranted when public reporting describes active targeting or patch uncertainty, especially in internet-facing Java services and third-party products bundling outdated Fastjson 1.x components.

The practical defender question is whether local controls can detect the likely exposure path and whether incident-response teams have playbooks for the business process affected by the threat.

## 5. Affected Sectors and Exposure

| Exposure Pattern | Why It Matters |
|------------------|----------------|
|------------------|----------------|

|                                           |                                                                                                             |
|-------------------------------------------|-------------------------------------------------------------------------------------------------------------|
| Public-facing service or portal           | Creates scanning, credential abuse, or outage exposure.                                                     |
| Third-party / supplier dependency         | Creates blind spots in logging, contractual response, and notification timelines.                           |
| Identity-federated SaaS or cloud platform | Enables data theft and persistence without traditional endpoint malware.                                    |
| Operational process dependency            | For aviation, healthcare, CI/CD, and software delivery, cyber events rapidly become business-impact events. |

## 6. Tactics, Techniques, and Procedures

| Tactic / Phase | Observed or Plausible Technique | Evidence                                                        |
|----------------|---------------------------------|-----------------------------------------------------------------|
| Initial Access | T1190                           | Exploit public-facing application                               |
| Execution      | T1059                           | Command execution after parser/deserialization exploit          |
| Persistence    | T1505                           | Potential web shell or service persistence after app compromise |

## 7. Infrastructure and Indicators

| Indicator / Infrastructure                     | Type              | Operational Use                                            |
|------------------------------------------------|-------------------|------------------------------------------------------------|
| No confirmed atomic IOC set                    | Source limitation | Use behavioral detections and local telemetry correlation. |
| Supplier/cloud/remote-support access paths     | Exposure class    | Prioritize inventory and access review.                    |
| User-reported support contact or outage ticket | Triage signal     | Correlate with authentication, endpoint, and network logs. |

## 8. Detection Engineering

### 8.1. Detection Summary

| Signal                                                             | Telemetry Source                       | Analytic Goal                                          |
|--------------------------------------------------------------------|----------------------------------------|--------------------------------------------------------|
| Unusual remote-support process execution or cloud-console activity | DeviceProcessEvents / Cloud audit logs | Detect initial access and hands-on-keyboard staging.   |
| New data export, large download, or anomalous object access        | SaaS / DLP / proxy logs                | Detect collection and exfiltration.                    |
| Operational service outage or error burst following auth change    | Application / service monitoring       | Catch impact before customer-facing disruption widens. |

### 8.2. Sigma / Detection Content

|                                                                                                                                                                             |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <pre> title: Suspicious Remote Support Or Supplier-Led Follow-On Activity status: experimental logsource:   product: windows   category: process_creation detection: </pre> |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

```

remote_tools:
  Image|contains:
    - 'QuickAssist'
    - 'AnyDesk'
    - 'TeamViewer'
    - 'ScreenConnect'
suspicious_child:
  CommandLine|contains:
    - 'whoami'
    - 'net user'
    - 'vssadmin'
    - 'rclone'
condition: remote_tools or suspicious_child
level: medium

```

### 8.3. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where FileName has_any
('QuickAssist.exe', 'AnyDesk.exe', 'TeamViewer.exe', 'ScreenConnect.ClientService.exe', 'powershell.exe', 'rclone.exe')
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Commands=make_set(ProcessCommandLine, 20) by DeviceName, AccountName, FileName
| order by LastSeen desc

```

## 9. Threat Hunting

### 9.1. Hunt Hypothesis

A supplier, social-engineering, cloud, or operational dependency path was abused before formal incident notification reached defenders.

### 9.2. Hunt Query

```

DeviceEvents
| where Timestamp > ago(14d)
| where ActionType has_any
('RemoteDesktopConnection', 'UserAccountCreated', 'AntivirusSignatureUpdateFailed', 'ExploitGuardNetworkProtectionBlocked')
| summarize Events=count(), Actions=make_set(ActionType, 20) by DeviceName, AccountName, bin(Timestamp, 1d)
| where Events > 5

CloudAppEvents
| where Timestamp > ago(14d)
| where ActionType has_any ('FileDownloaded', 'MassDownload', 'Add service principal', 'Consent to application', 'Update user')
| summarize Count=count(), Apps=make_set(Application, 20), IPs=make_set(IPAddress, 20) by AccountObjectId, AccountDisplayName
| where Count > 25

```

## 10. Risk Assessment

| Dimension  | Assessment                                                                                      |
|------------|-------------------------------------------------------------------------------------------------|
| Likelihood | Medium; selected due to recency, exposure breadth, or aviation/aerospace operational relevance. |
| Impact     | Medium to High depending on data sensitivity, operational dependency, and third-party access.   |
| Confidence | Medium unless primary victim/advisory details are available.                                    |

## 11. Recommended Actions

| Priority | Owner            | Action                                                                                       |
|----------|------------------|----------------------------------------------------------------------------------------------|
| Critical | SOC / IR         | Add the included behavior hunts to daily review for exposed business units.                  |
| High     | Identity / Cloud | Review third-party access, federation, consent grants, and anomalous downloads.              |
| High     | Operations       | Validate degraded-service playbooks and contact paths with key suppliers.                    |
| Medium   | Governance       | Track source updates and revise the report if primary disclosures add IOCs or victim detail. |

## 12. References

- [1] The Hacker News security index: <https://thehackernews.com/search?updated-max=2026-07-28T11:37:00+05:30&max-results=14>
- [2] Alibaba Fastjson project: <https://github.com/alibaba/fastjson>
- [3] NVD CVE search: <https://nvd.nist.gov/vuln/search/results?query=Fastjson>